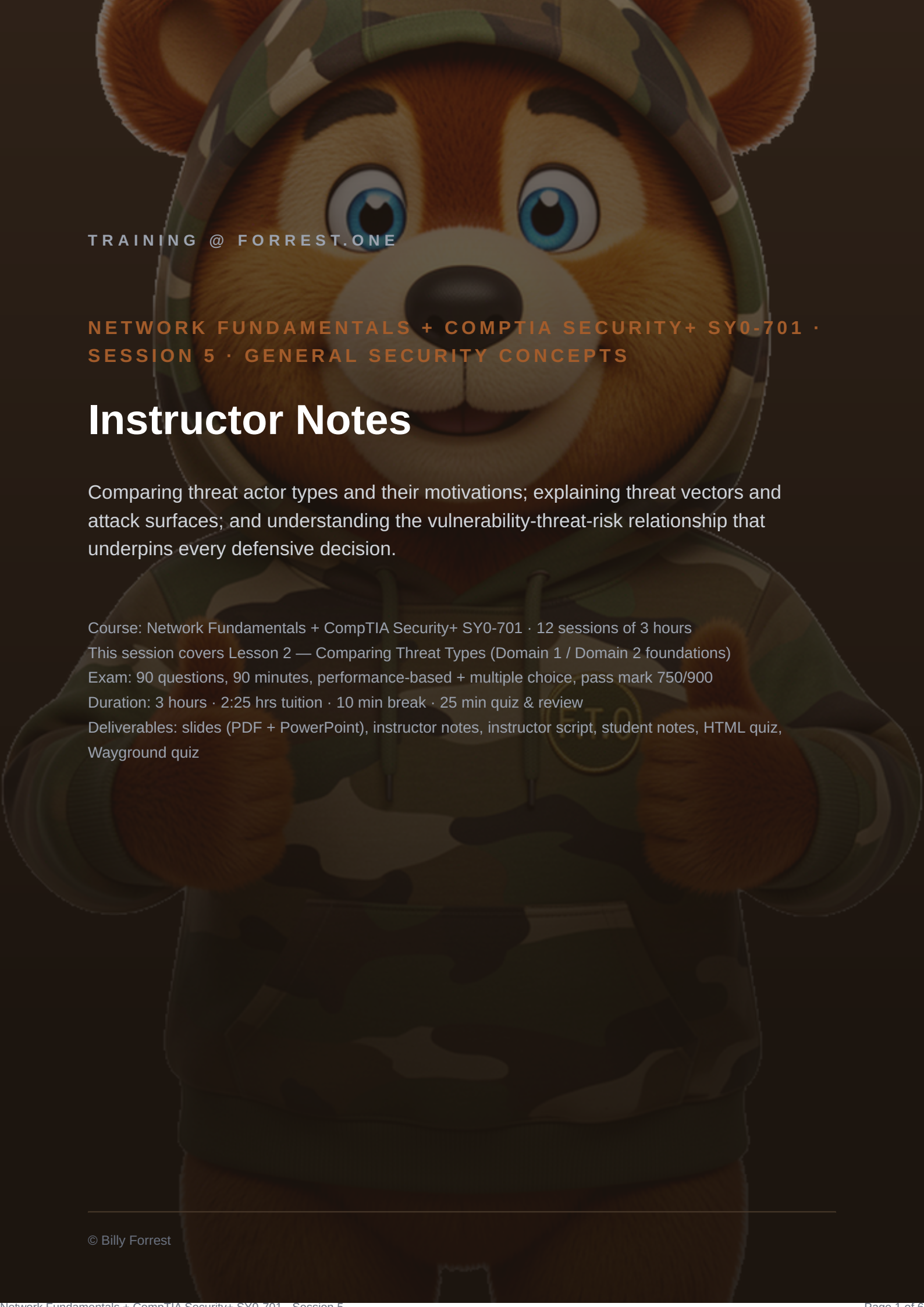




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 5 · GENERAL SECURITY CONCEPTS

Instructor Notes

Comparing threat actor types and their motivations; explaining threat vectors and attack surfaces; and understanding the vulnerability-threat-risk relationship that underpins every defensive decision.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session covers Lesson 2 — Comparing Threat Types (Domain 1 / Domain 2 foundations)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Instructor Notes — Threats, Attack Types & Threat Actors

A 3-hour delivery guide for Session 5. This is a classification-heavy session: actor types, motivations, vectors, vulnerabilities, attacks and controls. Keep candidates categorising out loud; the exam is scenario-based and rewards the ability to label an actor, a vector or a control quickly. Every attack in chapters four and five is paired on the slide with the defence that answers it, so the session closes on mitigation rather than on fear.

Session at a glance

Time	Block	Slides	Focus / activity
0:00–0:12	Welcome & objectives	1–3	Course position; the six-chapter map; session objectives
0:12–0:32	Risk, attributes & motivations	4–6	Vulnerability-threat-risk; the four attributes; five motivations
0:32–1:02	Actor types	7–12	APT and nation-state; organised crime; hacktivists and insiders; competitors and false flags; discussion; activity
1:02–1:22	Attack surface & human vectors	13–18	The surface; common vectors; phishing family; social engineering; network and file vectors; direct and remote access
1:22–1:32	Break	19	10-minute break
1:32–1:52	Vulnerabilities	20–23	Supply chain and software; application and web; operating system and hardware; mobile, cloud and virtualisation
1:52–2:07	Malware & credentials	24–28	Lifecycle; evasion; ransomware and rootkits; botnets; password attacks
2:07–2:22	Network attacks	29–35	Injection; denial of service; Layer 2; DNS; rogue devices and on-path; physical and cryptographic; activity
2:22–2:32	Mitigation & the attack chain	36–40	Segmentation; access control; hardening; isolation; the chain
2:32–3:00	Exam alignment, quiz & close	41–46	Objective map; Quiz_Session_05.html; takeaways; checklist; preview

Materials and preparation

- Projector or screen with the Session 5 slide deck (02_Slides.pdf or 02_Slides.pptx).

- One computer or tablet per pair for Quiz_Session_05.html.
- Printed or digital copy of the Student Notes for each candidate.
- Whiteboard or flipchart, split into two columns: name the attack, name the control.
- A current news story about a real attack for the discussion (optional but valuable).
- Brief notes on Stuxnet, WannaCry and NotPetya to illustrate the APT, unpatched software and the supply chain.

Delivery guidance by slide

Slides 1–3 · Welcome (12 minutes)

Frame the session around the adversary: defence only makes sense when you know who is attacking, why, and how. Emphasise the scenario-based nature of these exam questions. Show the six-chapter map on slide 2 so candidates know the session moves from actors to surface, to weaknesses, to attacks, and finishes on mitigation. Lock the vulnerability-threat-risk relationship on slide 4 before anything else, because it is the thread that ties all six chapters together.

Course position

Session 4 gave the CIA triad, controls and frameworks. This session is the threat half of Domain 2 and carries the largest single block of new terminology in the course. Chapter 6 (mitigation) is the half that earns marks in scenarios, so protect time for slides 36 to 39.

Slides 4–6 · Risk, attributes and motivations (20 minutes)

The attributes table on slide 5 is the classification tool: resources, sophistication, motivation and intent, matching the reference text. Resources set the scale, sophistication sets the method, motivation sets the reason and intent sets the outcome. Slide 6 adds the five motivation families and the ethical category, and introduces false flags early so slide 10 can build on it. Ask candidates to give one example target for each motivation to make the framework stick.

Slides 7–12 · Actor types (30 minutes)

Work through each type with a real-world example. Nation-state actors and APTs come first because the APT is the most tested actor type: emphasise stealth, persistence and the seven-stage campaign, and use Stuxnet, Operation Aurora and NotPetya as named cases. Organised crime is profit-driven and now rents its tools, so crime as a service lowers the entry bar. The hacktivist, unskilled attacker, malicious insider, negligent insider and shadow IT all appear on one table, and the point to land is that the insider is hardest to detect because the access is legitimate. Slide 10 covers competitors and false flags, which the quiz tests directly.

Discussion and activity (slides 11–12)

Discussion slide 11: which actor type most threatens your organisation, and why. Activity slide 12: match the actor, then name the motivation and the attack surface the scenario implies. 8 minutes in pairs, 4 minutes debrief. Land the negligence answer clearly: the employee who clicks a phishing link is a negligent insider, not a malicious one.

Slides 13–18 · Attack surface and human vectors (20 minutes)

The attack surface is everything an attacker can reach, and a vector is the path that reaches it. Slide 13 shows how cloud, mobile, Internet of Things and remote work each expand the surface. Slides 15 and 16 are the human half: the phishing family by target, then pretexting, baiting, tailgating, shoulder surfing and dumpster diving, with awareness training and easy reporting as the defence. Slide 17 covers the network and file-based vectors. Slide 18 adds direct access, remote access, open service ports, default credentials and the watering hole, and closes the chapter on the point that doors are closed by configuration.

Slide 19 · Break (10 minutes)

Ten minutes. When we return, the session turns from where an attacker can go to what they can abuse once they are there.

Slides 20–23 · Vulnerabilities (20 minutes)

An attack needs a vector and a vulnerability, so this chapter covers where the weaknesses live. Slide 20 links the supply chain to software: compromised updates reach every customer at once, which is the NotPetya model, and vendor credentials open the larger target. Slide 21 is the classic programming set, with SQL injection, cross-site scripting and the session attacks that follow from them. Slide 22 sits lower down the stack, and the point is that firmware and end-of-life flaws survive a reboot and sometimes a reinstall. Slide 23 covers mobile, cloud and virtualisation, where the quiet one is shared responsibility confusion: neither side secures what it assumed the other owned.

Slides 24–28 · Malware and credentials (15 minutes)

Malware has a lifecycle, and every stage is a chance to break it: delivery, exploitation and persistence. Then the categories, which candidates must name precisely: a virus needs a user, a worm spreads alone, a trojan is disguised. Slide 25 is evasion, and it explains why signature detection alone fails: polymorphism changes the code, encryption hides the payload, a rootkit hides the artefacts and fileless malware never touches the disk. Slide 26 adds double extortion, which defeats the argument that backups make payment pointless. Slide 27 covers botnets, command and control, and the two evasion tricks that keep the channel alive, domain generation algorithms and fast flux. Slide 28 is password attacks, where spraying is deliberately designed to stay under the lockout threshold.

Slides 29–35 · Attacks on the network (15 minutes)

Chapter five moves from weaknesses to attacks. Slide 29 is injection, and the single idea to land is that code and data must be kept separate. Slide 30 splits denial of service into volumetric, protocol, application layer and distributed, then adds amplification, where the victim receives a reply they never asked for. Slides 31 and 32 are the local network: Layer 2 attacks that succeed because the segment trusts itself, and DNS attacks that succeed because the name system is a trust system. Slide 33 covers rogue devices and on-path attacks, where encryption and certificate validation are the only real comfort. Slide 34 adds physical access and cryptographic attacks, and closes on salted hashing.

Activity (slide 35)

Name the attack, then name the control: fraudulent redirect with a clean cache (spoofing), a switch table full of invented addresses (address table flooding, answered by port security and dynamic ARP

inspection), a small spoofed request with a huge reply (amplification), a false gateway on a guest device (rogue DHCP server, answered by DHCP snooping). 8 minutes in pairs, 4 minutes debrief. Insist on both labels every time.

Slides 36–40 · Mitigation and the attack chain (10 minutes)

This is the defensive half, and it is the half that earns marks in scenarios. Segmentation contains an attack by turning one large network into many small ones. Access control limits what a compromise can reach: least privilege, need to know and separation of duties, with entitlements reviewed as roles change. Hardening removes what a system does not need, so every service switched off is a flaw that no longer needs a patch. Patch management is a discipline, not an event: inventory, assess, test, deploy and verify. Isolation assumes the attacker will get in: sandboxing, containerisation and air gaps each limit how far they get. Slide 40 then assembles the chain, recon, vector, exploit and act, and ties it to the APT lifecycle taught in chapter one.

Slides 41–46 · Exam alignment, quiz and close (30 minutes)

Walk the objective map on slide 41, which now spans the whole of Domain 2, from 2.1 to 2.5. Run the quiz, review low scores, walk both takeaways slides, and assign the checklist, including profiling one real threat group and pairing ten attacks from this session with the control that answers each. Preview Session 6.

Common misconceptions and corrections

Misconception	Correction
"All hackers are criminals"	White hats are ethical; the label describes activity, not intent
"Insiders are always malicious"	The negligent insider who falls for phishing is the more common case, and the harder one to detect
"APT means any advanced attack"	APT is persistent and strategic: long-term presence rather than a single strike
"The attack surface is the network"	It includes physical, human, cloud and supply chain elements, so people are part of the surface
"Patches fix everything"	End-of-life and zero-day flaws have no patch, so other controls must compensate
"A virus and a worm are the same thing"	A virus needs a user to run it; a worm spreads with no user action at all
"Backups make ransomware payment pointless"	Double extortion removes that argument: the data is stolen as well as encrypted
"DNS attacks are rare curiosities"	DNS is a trust system, so it is attacked constantly for redirection and credential theft
"Shadow IT is harmless if it works"	It places data outside approved controls, so it is an actor type on the exam, not a convenience

Discussion prompts and exam angles

- Ask which actor type would most value the data your organisation holds, and why. Tie the answer back to motivation, not just capability.
- Prompt candidates to turn a known breach into the attack chain: recon, vector, exploit, act. This rehearses the scenario-style question format.
- Test classification speed: give a one-line actor description and ask for type plus motivation in under thirty seconds, mirroring exam pacing.
- Emphasise the exam distinction between vulnerability (the weakness) and risk (weakness plus a threat that can exploit it).
- Run every attack through one question: which control in chapter six would have stopped it? That habit is what objective 2.5 tests.
- Use Stuxnet and NotPetya to contrast a supply chain update compromise with targeted state-sponsored persistence.
- Name the phishing family member precisely: broad phishing, spear phishing at a named individual, whaling at an executive, smishing by text and vishing by voice.

Exam angle

Scenario questions often pair an actor with a vector, or an attack with a control. Practise answering with both labels, for example 'hactivist, denial of service over a public web vector', because the exam rewards naming both parts.

Exam alignment check

- All session objectives map to exam objectives 2.1 to 2.5 of Domain 2.
- Quiz tags map every question to its exam objective for traceable revision.
- Scenario-style questions are used in both in-class activities to mirror the exam format.
- Every attack taught in chapters four and five is paired with a mitigation from chapter six.